

I need to share with you the two broad types of authentication mechanisms used by Web applications:

- Implicit authentication
- Explicit authentication

Implicit authentication by Web browsers

Implicit authentication by Web browsers occurs when the browser automatically includes authentication information in HTTP requests; in other words, the Web browser itself is responsible for tracking the authenticated state. Widely used implicit authentication mechanisms in the browser include:

- **HTTP authentication:** This enables the Web server to request authentication credentials from the browser in order to restrict access to certain Web pages. In all the three methods (basic, digest and NTLM), the initial authentication process undergoes the same basic steps. Figure 3 shows a simplified version of the authentication process. If the client requests further restricted resources that lie in the same authentication realm, the browser includes the credentials automatically in the request.
- **Cookies:** Web browser cookie technology provides persistent data storage on the client side, which is often used by today's Web applications to store authentication tokens. After a successful login procedure, the server sends a cookie to the client. Every subsequent HTTP request that contains this cookie is automatically regarded as authenticated. The typical cookie authentication process is shown in Figure 4.
- **Client-side SSL authentication:** The Secure Socket Layer (SSL), and its successor, the Transport Layer Security (TLS) protocol, enable cryptographically authenticated communication between the Web browser and the Web server. To authenticate, X.509 certificates and digital signature schemes are used.

What all these schemes have in common is that after a successful initial authentication, tokens are sent automatically in further requests, without asking the user for permission—this is what makes Web applications that use these authentication techniques, vulnerable to CSRF attacks.

Implicit authentication by IP address

This special case of implicit authentication is often found on intranets. Here, the authentication is based on certain IP (or MAC) addresses from which requests are made to the application. Shown in Figure 5 is a typical IP-based authentication, in which only users within the intranet are allowed to access the intranet server, and requests from all other IP addresses are denied access.

Explicit authentication is safer

In this type of authentication, the Web application (or the Web server) is itself responsible for tracking the authenticated state of the user. This is generally done in two ways:

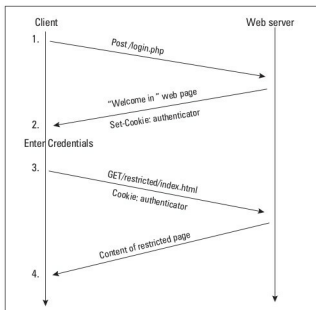


Figure 4: Typical cookie authentication

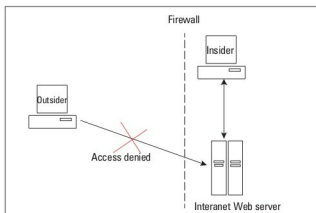


Figure 5: Typical IP-based authentication

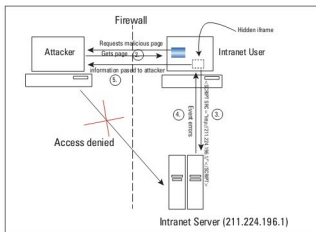


Figure 6: Port scanning intranet server

- **URL rewriting,** in which the session tokens are included in the URL for every request sent to the server; the URL